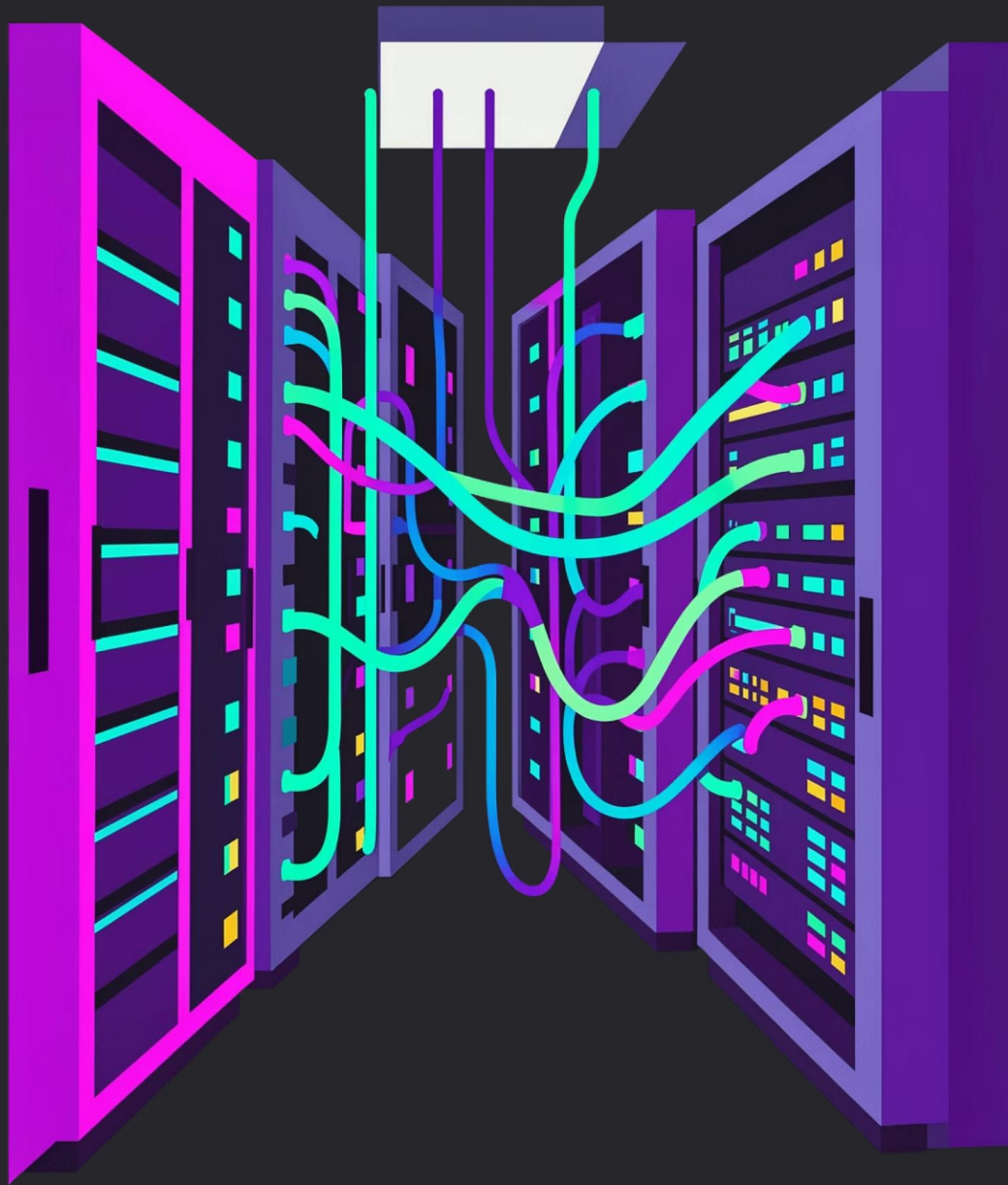


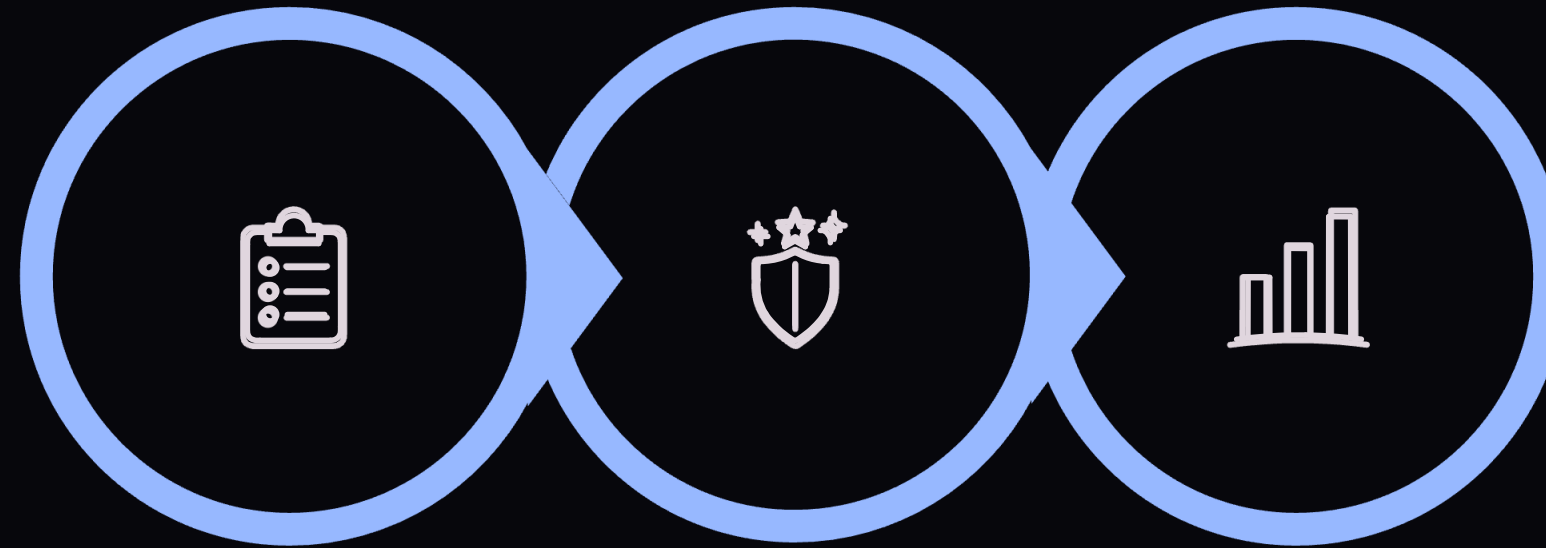


Week 3: Vendor Due Diligence

Healthcare-specific vendor risk assessments — evaluating ePHI exposure, clinical impact, and compliance posture across your third-party ecosystem.

EXECUTION • PART 1

Week 3 Objectives at a Glance



Assess
Vendors

Review
Evidence

Score & Rank

This week bridges policy into practice — moving from framework design to hands-on vendor interrogation using healthcare regulatory standards as the benchmark.



Healthcare Vendor Questionnaire

A structured questionnaire ensures every vendor is evaluated against the same clinical and regulatory baseline.

Questionnaire Coverage Areas



HIPAA Safeguards

Administrative, physical, and technical controls aligned to the Security Rule.



ePHI Encryption

Data-at-rest and in-transit encryption standards; key management practices.



Incident Response & Breach Notification

Breach detection timelines, HIPAA 60-day notification compliance, and escalation procedures.



Access Controls & MFA

Role-based access, least privilege, and multi-factor authentication enforcement.

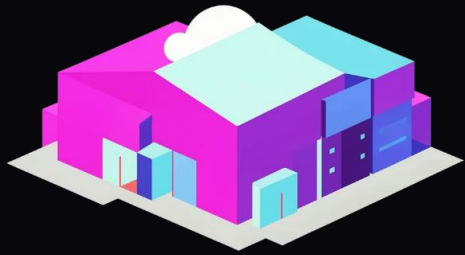


Medical Device Security

Network segmentation, firmware patching cadence, and FDA cybersecurity guidance alignment.

Simulated Vendor Responses

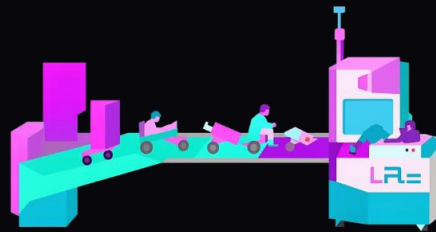
Three representative vendor archetypes were evaluated to reflect common hospital hosting scenarios.



Cloud Hosting Vendor

AWS GovCloud environment; SOC 2

Type II certified. Encryption at rest (AES-256) and in-transit (TLS 1.3). MFA enforced. BAA executed. Minor gap: patch notification SLA not contractually defined.



Medical Device Manufacturer

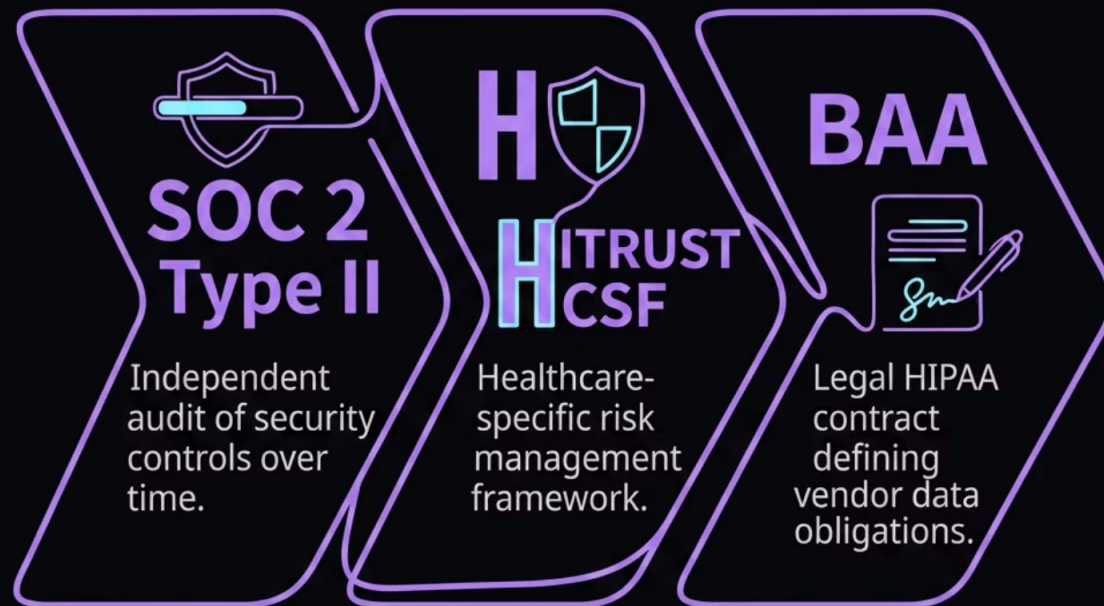
FDA 510(k) cleared device. No HITRUST certification. Firmware updates require manual coordination. Limited network segmentation documentation. BAA declined — vendor disputes ePHI scope.



Billing & Revenue Cycle Vendor

Processes ePHI for claims submission. HITRUST CSF certified. BAA in place. MFA enforced for portal access. SOC 2 Type II report available. Incident response plan tested annually.

Evidence Review Framework



What Reviewers Look For

- **SOC 2 Type II:** Covers a minimum 6-month period — point-in-time reports are insufficient.
- **HITRUST:** Validate certification scope — does it cover the specific systems handling your ePHI?
- **BAA:** Confirm subcontractor clauses, breach notification timelines, and data destruction terms.

⚠ A missing or out-of-scope BAA creates direct HIPAA liability for the covered entity — escalate immediately.

Vendor Risk Scoring Model

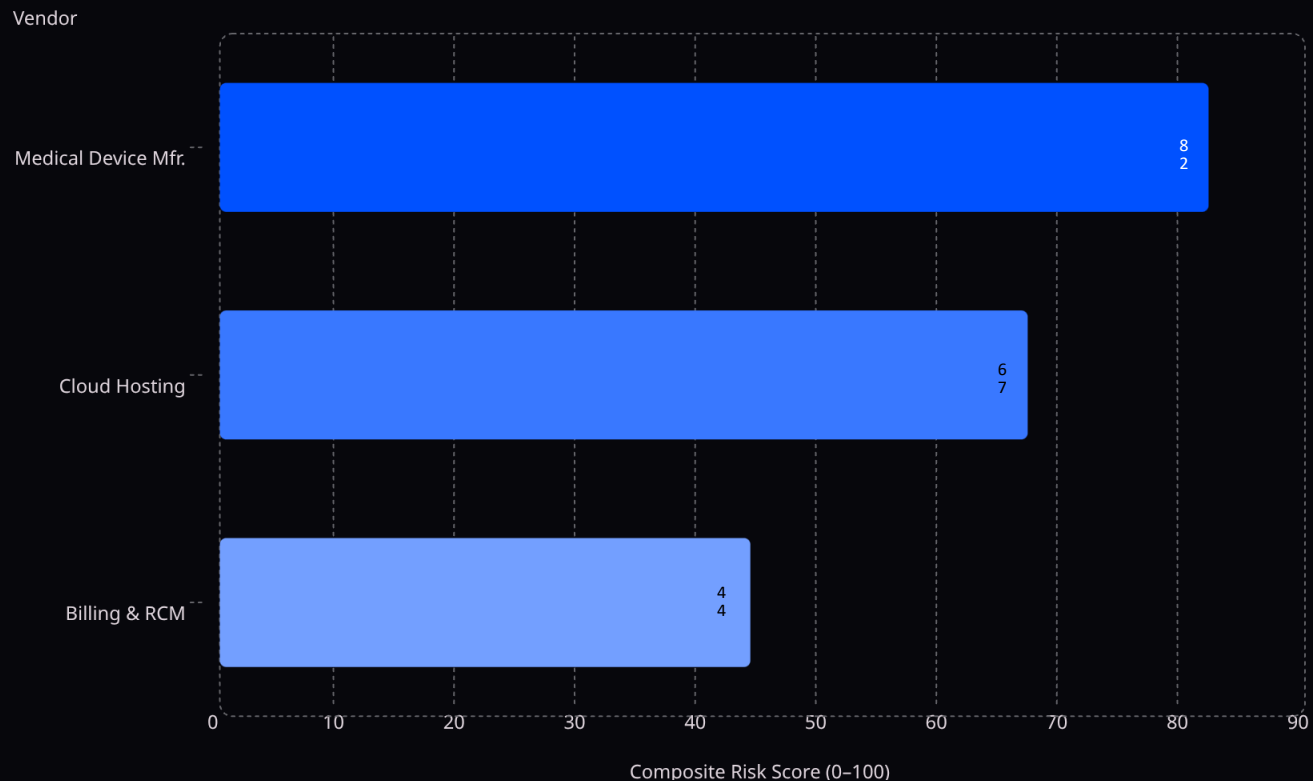
Vendors are scored across three weighted dimensions to prioritize remediation and contract action.

Vendor	ePHI Exposure	Clinical Impact	Integration Level
Cloud Hosting	High	Moderate	Deep (EHR-linked)
Medical Device Mfr.	Moderate	Critical	Direct patient care
Billing & RCM	High	Low	Transactional API

Scoring Dimensions

- **ePHI Exposure:** Volume and sensitivity of protected health information handled
- **Clinical Impact:** Effect on patient safety or care delivery if vendor fails
- **Integration Level:** Depth of system connectivity to hospital infrastructure

Risk Prioritization Outcome



Interpretation

The medical device manufacturer scores highest due to a combination of critical clinical impact, absent HITRUST certification, and an unresolved BAA dispute — requiring immediate escalation.

⊗ Scores above 75 trigger mandatory remediation within 30 days per hospital third-party risk policy.

Week 3 Deliverables



01

Due Diligence Checklist

Completed questionnaire mapped to HIPAA Security Rule domains, with per-vendor gap annotations and evidence status.

02

Simulated Vendor Responses

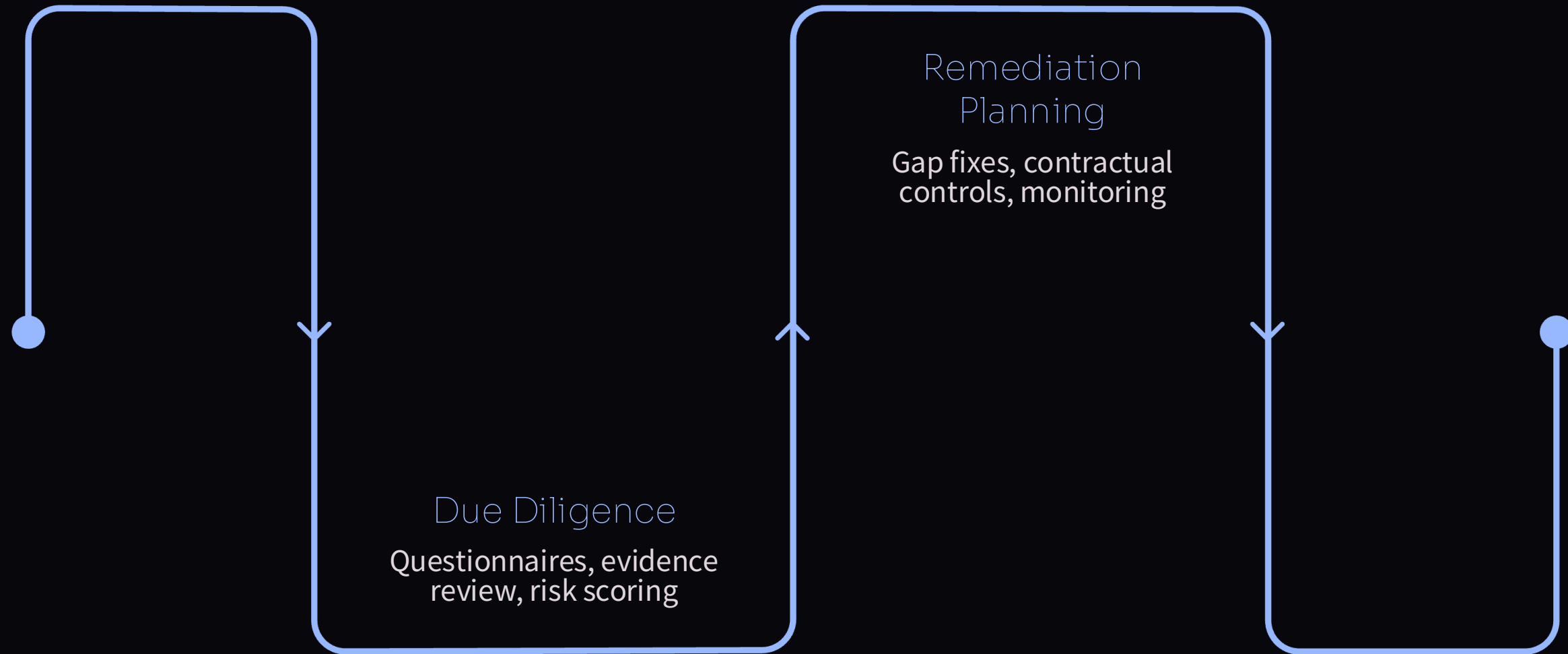
Documented responses from cloud hosting, medical device manufacturer, and billing/RCM vendor — including evidence artifacts received or outstanding.

03

Vendor Risk Scoring Table

Composite risk scores by ePHI exposure, clinical impact, and integration depth — with recommended next actions per vendor tier.

Looking Ahead: Week 4



Week 4 shifts focus to remediation planning — translating risk scores into contractual controls, vendor-specific action plans, and continuous monitoring protocols for high-exposure hospital systems.

 Vendors scoring above 75 should be notified of findings and required to submit a corrective action plan before Week 4 review.